

# Garil AI — SOC 2 Readiness Audit

Technical / code-evidence assessment against Trust Services Criteria (Security, Availability, Confidentiality, Processing Integrity, Privacy)

**Product:** GARIL AI · **Document date:** 28 September 2026 · **Method:** Static review of auth, APIs, data handling, deploy, governance UI · **Classification:** Internal — readiness only (not a formal I/II attestation)

**Blocking for any SOC 2 walkthrough.** Unauthenticated `/api/users` CRUD allows privilege escalation to super-admin. Default admin password `admin123` is auto-bootstrapped and can be reset on boot. Fix these before treating logical access (CC6) as testable.

~28%

Overall readiness

2

Critical blockers

14

High findings

8

Control strengths

## 1. Executive summary

This review assesses Garil AI’s codebase against SOC 2 Trust Services Criteria using concrete file evidence. It is **not** a formal SOC 2 Type I or Type II report. Formal attestation requires an independent CPA firm and organizational evidence (policies, vendor DPAs, HR/access, incident response runbooks) beyond application code.

Governance product surfaces (append-only audit log, retention UI, policy gates, university-scoped RBAC) are a useful foundation. The platform is **not SOC 2 ready** until critical logical-access failures and operational control gaps are closed.

## 2. Trust Services Criteria scores

Estimated control maturity from code evidence only (0–100).

|                           |                        |    |
|---------------------------|------------------------|----|
| Security (CC)             | <div><div></div></div> | 22 |
| Availability (A)          | <div><div></div></div> | 35 |
| Confidentiality (C)       | <div><div></div></div> | 30 |
| Processing Integrity (PI) | <div><div></div></div> | 28 |
| Privacy (P)               | <div><div></div></div> | 32 |

## 3. Critical & high findings

| Severity | ID | Finding                                                                                           | TSC        | Evidence                                                                     |
|----------|----|---------------------------------------------------------------------------------------------------|------------|------------------------------------------------------------------------------|
| Critical | F1 | Unauthenticated <code>/api/users</code> CRUD enables role escalation to admin                     | CC6.1      | <code>server.ts</code> ~1885–1922                                            |
| Critical | F2 | Default super-admin <code>admin@aula.com</code> / <code>admin123</code> ; boot may reset password | CC6.1      | <code>default-admin.ts</code> ;<br><code>bootstrap-admin.service.ts</code>   |
| High     | F3 | JWT in localStorage; no server revoke on logout / reset / suspend                                 | CC6.1      | <code>lib/auth.ts</code> ; <code>auth-token.ts</code> (7d TTL)               |
| High     | F4 | No rate limiting on auth, AI, or password-reset endpoints                                         | CC6.1 / A1 | No <code>@fastify/rate-limit</code> ;<br>nginx has no <code>limit_req</code> |

| Severity | ID  | Finding                                                                   | TSC     | Evidence                                                                                    |
|----------|-----|---------------------------------------------------------------------------|---------|---------------------------------------------------------------------------------------------|
| High     | F5  | CORS defaults to reflect any Origin when <code>CORS_ORIGIN</code> unset   | CC6.1   | <code>server.ts</code> CORS register                                                        |
| High     | F6  | Fastify logger disabled; no Sentry/APM; auth events not audited           | CC7     | <code>logger: false ;</code><br><code>loginUser</code> has no <code>recordAuditEvent</code> |
| High     | F7  | No CI / dependency scanning before Coolify auto-deploy                    | CC8     | No <code>.github/</code> ;<br>PROJECT_MANUAL notes absence                                  |
| High     | F8  | Student/research content sent to OpenRouter; no coded DPA/retention flags | C1 / P  | <code>llm.service.ts</code> ; <code>portal-ai.service.ts</code>                             |
| High     | F9  | Retention/deletion UI without purge job or cascade erase                  | P4 / PI | <code>admin-retention.service.ts</code> ;<br><code>deleteUser</code> account-only           |
| High     | F10 | Legal Terms / Privacy / AUP are explicit placeholders                     | P1      | <code>legal-documents.service.ts</code><br><code>DEFAULT_*</code>                           |

## 4. Criteria detail

### Security (CC) — weakest area

- **Gap** — Open user CRUD / dashboard stats
- **Gap** — Default admin + password re-sync on boot
- **Gap** — No MFA, logout, email verification
- **Gap** — Feature RBAC mostly UI; coarse admin API auth
- **Gap** — No Helmet / CSP / HSTS in app
- **OK** — script + salted passwords; timing-safe verify
- **OK** — Portal status/role reload from DB
- **OK** — University-scoped admin mutations

### Privacy & Confidentiality

- **Gap** — Placeholder legal documents
- **Gap** — No cascade erase / retention executor
- **Gap** — AI/cookie consent client-only (localStorage)
- **Gap** — Policy re-accept gate bypassable via API
- **Gap** — No portal access audit for student work
- **OK** — Registration policy acceptance required
- **OK** — Versioned legal publish + `accountPolicyVersion`
- **OK** — Admin title redaction (HMAC labels)

### Availability & operations

- **OK** — `/api/health` + Docker/PM2/systemd restarts
- **OK** — Mongo connect retries in production
- **Gap** — Health ignores Mongo; always `ok: true`
- **Gap** — Research jobs in-memory; lost on restart
- **Gap** — JSON backup incomplete; no restore path
- **Gap** — Compose Mongo without auth / exposed port

### Change mgmt, logging, monitoring

- **OK** — Append-only AuditLog + immutableHash
- **OK** — Governance alerts/incidents admin UI
- **Gap** — `logger: false` — no structured request logs
- **Gap** — No CI gates; Coolify auto-deploy from main
- **Gap** — Alert notify stubs (console.log / optional webhook)
- **Gap** — No Dependabot / npm audit / CodeQL

## 5. Remediation roadmap

### Week 1 — Stop the bleed

1. Auth-gate or remove `/api/users` and open dashboard routes
2. Disable default admin in prod (`DEFAULT_ADMIN_ENABLED=false`); rotate secrets
3. Set explicit `CORS_ORIGIN`; enable Fastify logger
4. Add rate limits on login / forgot-password / AI

### Weeks 2–4 — Control foundation

5. httpOnly cookie sessions or token version + revoke
6. CI: lint, typecheck, dependency audit before deploy
7. Sentry (or equiv) + auth audit events
8. Publish real Terms/Privacy/AUP; server-enforce policy version
9. Helmet/security headers; sanitize portal HTML

### Weeks 5–10 — SOC 2 readiness

10. Cascade erase + retention job; user export/delete
11. Subprocessor inventory + OpenRouter DPA / retention settings
12. Scheduled backups + tested restore; Mongo-aware health
13. MFA for admins; password policy; email verify
14. IR runbook, on-call alerts, vendor risk register (org)

## 6. Formal SOC 2 still needs (outside code)

Even after engineering gaps are closed, Type I/II requires organizational evidence an auditor will sample:

| Area              | Expected evidence                                               | In-repo today                              |
|-------------------|-----------------------------------------------------------------|--------------------------------------------|
| Security policies | Approved info-sec, access, change, IR policies                  | Governance UI only — no policy docs as SoA |
| Vendor management | DPAs for OpenRouter, Resend, Mongo/S3 host, Coolify             | API keys in env; no DPA artifacts          |
| HR / access       | Onboarding/offboarding checklists; background checks if claimed | Not present                                |
| Change control    | PR review, CI pass, deploy approvals, rollback                  | Coolify auto-deploy; no GitHub Actions     |
| Monitoring / IR   | On-call, ticketed incidents, postmortems                        | In-app incidents; notify mostly stubs      |
| Availability      | RTO/RPO, backup tests, uptime SLO                               | Partial healthchecks; incomplete backups   |

## 7. Bottom line

---

Governance product surfaces (audit log, retention UI, policy gates, university RBAC) are a useful foundation, but the platform is **not SOC 2 ready**. Prioritize **F1–F2** immediately — they are exploitable logical access failures — then build observability, CI, privacy enforcement, and organizational evidence for an auditor engagement.

## 8. Key evidence paths

---

```
backend/src/server.ts · backend/src/services/auth.service.ts · backend/src/lib/require-admin.ts ·  
backend/src/lib/portal-auth.ts · backend/src/constants/default-admin.ts · lib/auth.ts ·  
backend/src/services/legal-documents.service.ts · backend/src/services/admin-retention.service.ts ·  
backend/src/services/admin-audit.service.ts · backend/src/services/llm.service.ts · docker-  
compose.yml · deploy/README.md
```

---

Garil AI — SOC 2 Readiness Audit · 28 September 2026 · Internal technical assessment. This document does not constitute a SOC 2 Type I or Type II report and is not legal advice.